FUTURES MATTER EDUCATION

Futures Matter - Northwood, 122 Emily Street, Highgate, Birmingham, B12 0XJ

Data Protection Policy

Reference: FME-GD-02

Last review: September 2026
Next review: September 2027

Reviewed by: Benjamin Neasom, Head Teacher
Carrie-Ann McGurk, Proprietor
Mark O'Donnell, Chair of School Governance Board

CONTENTS

1.0AIMS 2
2.0LEGISLATION AND GUIDANCE 2
3.0WHAT WE MEAN BY 2
4.0THE DATA CONTROLLER AND ROLES 3
5.0DATA PROTECTION PRINCIPLES 4
6.0COLLECTING PERSONAL DATA 4
7.0SHARING PERSONAL DATA 5
8.0INDIVIDUALS' RIGHTS AND ACCESS REQUESTS 5
9.0PARENTS AND THE EDUCATIONAL RECORD 6
10.0PHOTOGRAPHS, VIDEOS, CCTV AND BIOMETRICS 6
11.0ARTIFICIAL INTELLIGENCE (AI) 7
12.0DATA PROTECTION BY DESIGN AND DEFAULT 7
13.0DATA SECURITY, STORAGE AND DISPOSAL 8
14.0PERSONAL DATA BREACHES 8
15.0COMPLAINTS 9
16.0TRAINING AND MONITORING 9
17.0LINKS WITH OTHER POLICIES 9
18.0APPENDICES 9
APPENDIX 1: PERSONAL DATA BREACH PROCEDURE 10
APPENDIX 2: UK GDPR AUDIT 12

1.0 AIMS

At Futures Matter - Northwood we hold sensitive information about our pupils, their families, our staff and others. Our pupils all have EHC plans, and we hold information about their health, needs, behaviour and safeguarding. We take our responsibility to look after this information very seriously. This policy aims to make sure that all personal data collected about staff, pupils, parents and carers, governors, visitors and other individuals is collected, stored and processed in line with UK data protection law.

This policy applies to all personal data, whether it is on paper or in electronic form.

2.0 LEGISLATION AND GUIDANCE

This policy meets the requirements of the:

- UK General Data Protection Regulation (UK GDPR)
- Data Protection Act 2018
- Data (Use and Access) Act 2025, including the requirement from 19 June 2026 to give people a way to make data protection complaints to the school

It is based on guidance and resources published by the Information Commissioner's Office (ICO) on the UK GDPR, and the DfE's guidance on data protection in schools and its policy paper on generative artificial intelligence in education. It also reflects the ICO's guidance on the use of surveillance cameras and personal information, and the Protection of Freedoms Act 2012 for any use of biometric data. It should be read with the Safeguarding and Child Protection Policy, which explains how and when we share information to keep children safe.

As an independent school, there is no automatic right for parents to see their child's educational record under the Education (Pupil Information) (England) Regulations 2005. Section 9 explains our approach.

3.0 WHAT WE MEAN BY

Term	Meaning
Personal data	Any information about an identified or identifiable living person, directly or indirectly. It includes a name, an identification number, location data and an online identifier such as a username. It also includes factors specific to a person's physical, mental, economic, cultural or social identity.
Special categories of personal data	More sensitive personal data that needs more protection. It includes information about racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetics, biometrics used for identification, health (physical or mental), and sex life or sexual orientation. Most of the information we hold about our pupils' needs is in this group.
Processing	Anything done with personal data, such as collecting, recording, organising, storing, changing, retrieving, using, sharing, erasing or destroying it. It can be done by computer or by hand.
Data subject	The person whose personal data is held or processed.

Term	Meaning
Data controller	The person or organisation that decides the purposes and means of processing personal data. The school is a data controller.
Data processor	A person or organisation, other than an employee of the controller, that processes personal data on behalf of the controller and only on its instructions, for example a payroll provider or an IT company.
Personal data breach	A security breach that leads to the accidental or unlawful destruction, loss, change, unauthorised disclosure of, or access to, personal data.

4.0 THE DATA CONTROLLER AND ROLES

The school processes personal data about parents and carers, pupils, staff, governors, visitors and others, and so acts as a data controller. **The school is registered with the ICO and has paid its data protection fee. Registration number: ZC057236**

This policy applies to all staff employed by the school, and to external organisations and individuals working for us. Staff who do not follow this policy may face disciplinary action.

Who	Responsibilities
The Proprietor and the School Governance Board	Have overall responsibility for making sure the school meets its data protection duties. Receive a report from the DPO at least once a year, and straight away after a serious data breach. The full Board approves this policy, as it covers biometric data and photographs of pupils.
The Data Protection Officer (DPO)	Our DPO is Kirsty Chamberlain, the Finance and Business Support Manager. Oversees this policy, monitors our compliance with data protection law, and advises on related policies and notices. Is the first point of contact for people whose data we hold and for the ICO. Advises on data protection impact assessments. Contact: office@futuresmattereducation.co.uk or 0121 835 1360. Please contact the DPO with any question about this policy or the UK GDPR, or any concern that the policy is not being followed.
The Head Teacher	Is the representative of the data controller on a day-to-day basis, and is the lead for data protection decisions about pupils. Is told straight away of any serious breach. The Head Teacher is also the Designated Safeguarding Lead and decides what safeguarding information is shared. The Proprietor, Carrie-Ann McGurk, acts when the Head Teacher is away.

Who	Responsibilities
All staff	Collect, store and process personal data in line with this policy. Tell the school about changes to their own personal data, such as a change of address. Contact the DPO if they have a question about this policy, data protection law, keeping or securing personal data, or if they are unsure whether they have a lawful basis to use data in a particular way. Also contact the DPO if they need to rely on or record consent, write a privacy notice, deal with a request from an individual, or send personal data outside the UK. Tell the DPO about any data breach, and before starting a new activity that may affect people's privacy, or before sharing data with a third party.

5.0 DATA PROTECTION PRINCIPLES

We follow the principles in the UK GDPR, which say that personal data must be:

- processed lawfully, fairly and in a transparent way (lawfulness, fairness and transparency)
- collected for specified, explicit and legitimate purposes (purpose limitation)
- adequate, relevant and limited to what is necessary (data minimisation)
- accurate and, where necessary, kept up to date (accuracy)
- kept for no longer than is necessary (storage limitation)
- processed in a way that keeps it secure (security, integrity and confidentiality)
- not transferred to another country without appropriate safeguards (transfer limitation)
- handled in a way that respects people's rights and lets them use those rights

We are responsible for showing that we meet these principles (accountability). This policy sets out how we do so.

6.0 COLLECTING PERSONAL DATA

Lawfulness, fairness and transparency. We only process personal data where we have one of the lawful bases in data protection law:

- to fulfil a contract with the person, or at their request before a contract
- to comply with a legal obligation
- to protect someone's life (vital interests)
- for a legitimate interest of the school or of a third party, where this does not override the person's rights and freedoms, including a recognised legitimate interest set out in law
- with the clear, freely given consent of the person, or of their parent or carer where that is appropriate for a pupil

Because we are an independent school and not a public authority, we do not generally rely on the 'public task' basis. For special category data, we also meet one of the special category conditions, such as explicit consent, employment law obligations, vital interests, legal claims, substantial public interest (for example safeguarding children and individuals at

risk), or health and social care purposes. For criminal offence data, we meet both a lawful basis and a condition in law, such as safer recruitment and safeguarding.

When we first collect personal data from people, we give them the information that data protection law requires, in privacy notices. We think about fairness: we do not handle personal data in ways people would not reasonably expect, or use it in ways that have unjustified harmful effects.

Limitation, minimisation and accuracy. We only collect personal data for specified, explicit and legitimate reasons, and explain those reasons when we first collect it. If we want to use it for another reason, we tell the people concerned first, and ask for consent where necessary. Staff only process personal data where it is necessary for their job. We keep data accurate and, where necessary, up to date, and we correct or delete inaccurate data. When staff no longer need personal data, they delete or anonymise it, in line with our records retention schedule.

7.0 SHARING PERSONAL DATA

We do not share personal data with third parties unless safeguards and agreements are in place, but there are times when we must or should share it. These include where:

- there is an issue with a pupil, parent or carer that puts staff at risk
- we need to work with other agencies, such as the placing local authority, social workers, health professionals, children's services, the police and the virtual school. We seek consent as necessary, except where sharing is needed to keep a child safe (see the Safeguarding and Child Protection Policy)
- our suppliers or contractors, such as IT companies and our case management system (CPOMS), need data to provide services to us. We only appoint suppliers who can show they follow UK data protection law, have a contract with them, and share only the data they need

Data protection law does not stop us sharing information to keep a child safe, and fear about data protection must never prevent staff from sharing safeguarding information. We also share personal data with law enforcement and government bodies where we are legally required to, and with emergency services and local authorities to help them respond in an emergency. We send personal data about pupils to local authorities and other agencies by encrypted email or a secure portal. If we transfer personal data outside the UK, we do so in line with UK data protection law.

8.0 INDIVIDUALS' RIGHTS AND ACCESS REQUESTS

Subject access requests (SARs). People have the right to ask for the personal information the school holds about them. This includes confirmation that we process their data, a copy of it, the purposes, the categories of data, who it has been shared with, how long we keep it, their rights to ask us to correct, delete or restrict it, the right to complain to the ICO, where the data came from, and whether any automated decision-making is used. A request can be made in any form, but we can respond faster if it is in writing and gives the person's name, address, contact details, and the information they want. Staff who receive a SAR, in any form, must send it to the DPO straight away.

Children and SARs. Personal data about a child belongs to the child, not to their parents or carers. A parent or carer can only make a SAR for their child if the child cannot understand

their rights and what the request means, or has agreed to it. Our pupils are aged 11 to 16, and they have special educational needs. We therefore judge each pupil's understanding case by case, taking account of the pupil's needs and communication, and we do not assume the answer from their age alone. Where a pupil is able to understand, we ask for the pupil's agreement before giving a parent or carer their personal data.

Responding to SARs. We may ask for 2 forms of identification, and may phone the person to confirm the request. We respond without delay and within 1 month of receiving the request, or of receiving the information we need to confirm identity. We do not charge. Where a request is complex or there are many, we may extend the time to 3 months, and we tell the person within 1 month and explain why. These times apply during school holidays. The school may stop and ask for clarification when the request is unclear, in line with ICO guidance, and we carry out reasonable and proportionate searches.

We may not give some information, for example where it might cause serious harm to the physical or mental health of the pupil or another person, would reveal that a child is or has been abused or is at risk of abuse and disclosure would not be in the child's best interests, includes another person's data that we cannot reasonably remove and we do not have consent, or is part of sensitive documents such as those related to crime, legal proceedings or legal privilege, management forecasts, negotiations, confidential references, or exam scripts. If a request is unfounded or excessive, we may refuse it or charge a reasonable fee. When we refuse, we say why, and tell the person they can complain to the ICO or go to court.

Other rights. People can also withdraw consent at any time, ask us to correct, delete or restrict the processing of their data in certain circumstances, object to processing that we base on legitimate interests, prevent use of their data for direct marketing, challenge decisions based only on automated decision-making or profiling, be told of a personal data breach in certain circumstances, ask for their data in a structured, machine-readable form to move to another organisation, and complain to the ICO. People should send any request to the DPO. Staff who receive one must send it to the DPO straight away.

9.0 PARENTS AND THE EDUCATIONAL RECORD

As an independent school, we are not legally bound by The Education (Pupil Information) (England) Regulations 2005. However, we have chosen to adopt similar practices to ensure transparency and good working relationships with families.

Access to educational records:

- Parents and carers can request to view or receive copies of their child's educational record
- We will respond to written requests within 15 school days
- There is no charge for viewing the record
- If you request copies, we may charge a reasonable fee to cover the actual cost of printing and sending the information

Subject Access Requests:

- Parents and carers can also request information about their child through a Subject Access Request (SAR) under UK GDPR

- SARs are handled differently - see section 8 of this policy for full details
- We respond to SARs within one month and cannot charge a fee (except in limited circumstances)

When we may withhold information: We may refuse to disclose information where:

- It may cause serious harm to the physical or mental health of the pupil or another person
- It would reveal examination marks before they are officially announced
- The pupil is competent to make their own decisions and has not consented to disclosure

If we are unsure whether disclosure might cause serious harm, we will seek advice from our legal team before making a decision.

10.0 PHOTOGRAPHS, VIDEOS, CCTV AND BIOMETRICS

Photographs and videos. We may take photographs and record images of individuals in school, and on visits. We get written consent from parents and carers, or from pupils aged 18 and over, before photographs and videos of pupils are used in communications, marketing or promotional material. Where we need parental consent, we explain how the image will be used to both the parents or carers and the pupil. Where we do not need parental consent, we explain it to the pupil. Uses may include notice boards, brochures and newsletters in school, external agencies such as the school photographer or newspapers, and our website or social media. Consent can be refused or withdrawn at any time. If it is withdrawn, we delete the image and do not share it further. We do not put other personal information, such as a pupil's full name, next to an image in a way that identifies them. Staff take photographs on school devices only, not personal phones. Parents and carers can take photographs at school events for their own use, which data protection law does not cover, but we ask that images of other pupils are not shared publicly on social media unless all the relevant parents and carers have agreed. Our Safeguarding and Child Protection Policy and Online Safety Policy give more detail.

CCTV and biometrics. We use CCTV to keep our site safe and secure. Our use of CCTV follows the Information Commissioner's Office (ICO) guidance on surveillance cameras.

We ensure that:

- Clear signs are displayed at the entrance of CCTV-monitored zones and throughout monitored areas
- Signs are clearly visible and readable, and include:
    - Details of our school as the organisation operating the system
    - The purpose for using CCTV
    - Contact details for enquiries (name, email address and/or telephone number)
- Our privacy notices explain how we use CCTV, how long footage is kept, and who we might share it with
- CCTV footage is only kept for as long as necessary and is then securely deleted
- Only trained and authorised staff can access CCTV footage
- We have clear processes for reviewing and managing CCTV footage

For any enquiries about our CCTV system, please contact Carrie-Ann McGurk Proprietor carrie-ann@futuresmattereducation.co.uk.

We do not use biometric recognition systems (such as fingerprint scanners) at our school.

11.0 ARTIFICIAL INTELLIGENCE (AI)

AI tools, such as the chatbots ChatGPT and Google Gemini, are now widely available. Futures Matter - Northwood recognises that AI has many uses to help pupils learn, and that it also risks the security of sensitive and personal data. To keep this data secure, no one is allowed to enter personal or sensitive data into an unauthorised generative AI tool or chatbot. Where it is strictly necessary to use personal data in an AI tool, the Head Teacher and the DPO must approve it first, and a data protection impact assessment is carried out, and our privacy notices are updated to say so. If personal or sensitive data is entered into an unauthorised AI tool, we treat this as a data breach and follow the breach procedure in Appendix 1.

12.0 DATA PROTECTION BY DESIGN AND DEFAULT

We put measures in place to show that data protection is part of everything we do, including:

- appointing a suitably qualified DPO, and giving them the resources they need
- only processing the personal data that is necessary for each purpose, and always in line with the principles in section 5
- completing data protection impact assessments (DPIAs) where processing is likely to be a high risk to people's rights and freedoms, and when we bring in new technology. The DPO advises on this
- including data protection in our policies and privacy notices
- training staff in data protection law, this policy and related policies, and keeping a record of who attended
- regularly reviewing and auditing our privacy measures using the UK GDPR audit (Appendix 2)
- putting safeguards in place if we send any personal data outside the UK
- keeping a record of our processing activities, including the type of data and the people it is about, how and why we use it, anyone we share it with, any transfers outside the UK and the safeguards, how long we keep it, and how it is kept secure
- making privacy notices available for pupils, parents and carers, staff, governors and volunteers, job applicants, visitors and suppliers, with the name and contact details of the school and the DPO

13.0 DATA SECURITY, STORAGE AND DISPOSAL

We protect personal data and keep it safe from unauthorised or unlawful access, changing, processing or disclosure, and against accidental or unlawful loss, destruction or damage. In particular:

- paper records, and portable electronic devices such as laptops and hard drives that hold personal data, are kept locked away when not in use
- papers with confidential personal data are never left on desks, on tables in the staffroom, or anywhere with general access

- where personal information has to be taken off site, staff sign it in and out from the school office
- passwords are made up of 4 random, unrelated words, or are at least 10 characters long with letters and numbers, and are not reused from other sites
- all portable devices and removable media, such as laptops and USB devices, are protected with encryption software
- staff, pupils or governors who keep personal information on their own devices follow the same security rules as for school equipment (see our Online Safety and Acceptable Use Policy)
- emails with sensitive data are encrypted, and email addresses are checked before sending
- where we share data with a third party, we do due diligence and take reasonable steps to make sure it is stored securely (section 7)

Retention and disposal. We keep personal data for no longer than is necessary, in line with our records retention schedule. Personal data that is no longer needed, or is inaccurate or out of date and cannot or does not need to be corrected, is disposed of securely. We shred paper records, and overwrite or delete electronic files. We may use a third party to dispose of records safely for us, and if so we require it to show that it follows data protection law. We keep a record of what has been destroyed.

14.0 PERSONAL DATA BREACHES

We make all reasonable efforts to make sure there are no personal data breaches. If a breach is suspected, we follow the procedure in Appendix 1. Where appropriate, we report the breach to the ICO within 72 hours of becoming aware of it. Breaches in a school context may include:

- safeguarding information being made available to an unauthorised person
- the theft or loss of a school laptop or device that holds unencrypted personal data about pupils
- an email or letter with personal data about a pupil being sent to the wrong person or family
- a dataset that has not been anonymised, such as information about pupils' needs or funding, being published on the website
- personal data about pupils or staff being entered into an unauthorised AI tool

We also notify the people concerned where we are legally required to.

15.0 COMPLAINTS

We take complaints about how we collect and use personal information very seriously. If you think our collection or use of personal information is unfair, misleading or inappropriate, or you have any other concern about our data processing, please raise it with us first. You can make a complaint at any time to the DPO, Kirsty Chamberlain, at office@futuresmattereducation.co.uk or on 0121 835 1360, or by writing to Futures Matter - Northwood, 122 Emily Street, Highgate, Birmingham, B12 0XJ. When we get a complaint, we will:

- acknowledge it within 30 days of receiving it

- without undue delay, take appropriate steps to respond, including making enquiries based on the circumstances of the complaint and keeping the person informed of progress
- without undue delay, tell the person the outcome of the investigation

You can also complain to the Information Commissioner's Office at ico.org.uk or on 0303 123 1113. Our Complaints Policy applies to other complaints about the school.

16.0 TRAINING AND MONITORING

All staff and governors have data protection training as part of their induction. Data protection is also part of continuing professional development, where changes to the law, guidance or our processes make it necessary, and we keep a record of who has been trained. The DPO is responsible for monitoring and reviewing this policy, and gives a report to the Board each year. The policy is reviewed every year, and approved by the full School Governance Board.

17.0 LINKS WITH OTHER POLICIES

- Safeguarding and Child Protection Policy
- Online Safety and Acceptable Use Policy
- Filtering and Monitoring Policy
- Complaints Policy
- Staff Code of Conduct
- Children Missing Education and Missing Pupils Policy
- Educational Visits Policy
- Privacy notices, and the records retention schedule (to be created)

References: UK GDPR; Data Protection Act 2018; Data (Use and Access) Act 2025; ICO guidance; DfE, Data protection in schools.

18.0 APPENDICES

Appendix 1: Personal Data Breach Procedure

Appendix 2: UK GDPR Audit

APPENDIX 1: PERSONAL DATA BREACH PROCEDURE

This procedure is based on the ICO's guidance on personal data breaches.

Step	What happens
1. Report	On finding or causing a breach or potential breach, the staff member, governor or data processor tells the DPO straight away by email to office@futuresmattereducation.co.uk or by phone on 0121 835 1360, and the Head Teacher.
2. Investigate	The DPO investigates and decides whether a breach has happened, by considering whether personal data has been accidentally or unlawfully lost, stolen, destroyed, changed, disclosed or made available where it should not have been, or made available to unauthorised people. Staff and governors help with the investigation. It is not a disciplinary investigation.
3. Alert	If a breach has happened or is likely, the DPO alerts the Head Teacher and the Chair of the School Governance Board. If safeguarding information is involved, the DPO tells the DSL.
4. Contain	The DPO makes all reasonable efforts to contain the breach and reduce its impact, with help from staff and our IT provider. See the actions at the end of this procedure.
5. Assess	The DPO assesses the likely consequences, based on how serious they are and how likely they are, before and after the steps taken. The DPO works out whether the breach must be reported to the ICO and to the people affected, using the ICO's self-assessment tool, and documents the decision either way.
6. Report to the ICO	Where the ICO must be told, the DPO reports on the ICO website's 'report a breach' page, or by phone on 0303 123 1113, within 72 hours of the school becoming aware of the breach. The report describes the nature of the breach, the categories and approximate number of people and records, the DPO's contact details, the likely consequences, and the measures taken. If the details are not yet known, the DPO reports what can be given, explains the delay, and sends the rest as soon as possible.
7. Tell people affected	Where we must tell the people whose data was breached, the DPO writes to them in clear, plain language, saying what happened, the DPO's contact details, the likely consequences and the measures taken. The DPO considers whether to tell third parties who can reduce the harm, such as the police, insurers, banks or card companies.
8. Record	The DPO documents every breach, whether or not it is reported to the ICO, including the facts and cause, the effects, and the action taken to contain it and stop it happening again. Records are stored in a restricted folder on the school's secure system.

Step	What happens
9. Review	The DPO and the Head Teacher meet as soon as reasonably possible to review what happened and how to stop it happening again, and then each term to look at all recorded breaches for trends. The DPO reports to the Board.

Type of breach	Actions to reduce the impact
Sensitive information, including safeguarding records, sent by email to the wrong person	The sender tries to recall the email as soon as they know. Anyone who receives data in error tells the sender and the DPO straight away. If the email cannot be recalled, the DPO asks our IT provider to recall or remove it, keeping a copy as evidence. The DPO considers contacting the people who received it, explaining the error and asking them to delete it and not to share it, and tries to get written confirmation. The DPO searches the internet to check it has not been made public, and if it has, asks the site owner to remove it. If safeguarding information is involved, the DPO tells the DSL, who decides whether to tell the local safeguarding partners and the placing local authority.
A school laptop or device with unencrypted personal data lost or stolen	Report it to the DPO and the Head Teacher straight away. Remotely lock or wipe the device where possible. Report a theft to the police and keep the reference number.
Paper records or letters sent to the wrong family	Contact the person who received it by phone, ask them to return or destroy it, and record that they have done so. The DPO assesses whether the person affected must be told.
Personal data entered into an unauthorised AI tool	Stop using it. The DPO assesses the risk, asks the provider to delete the data where possible, and records the breach.

APPENDIX 2: UK GDPR AUDIT

This audit is based on The Key's UK GDPR audit (April 2026), which reflects the statutory requirements and good practice. The DPO, with the Head Teacher, completes it each year and reports the result to the Board. Work through each section with the person who leads on that area. Rate each measure red (not done), amber (in progress) or green (complete), and note the steps taken so far and the future actions. Where a document is out of date, or staff do not know where it is, note the changes needed. If a measure cannot reasonably be done at a school of our size, record why. Add rows for anything else that applies.

DOCUMENTS - note the changes needed and tick when the document is present	
Record of processing activities (check the lawful basis, conditions and any safeguards for transfers outside the UK):	
Privacy notices (for pupils, parents and carers, staff, governors and volunteers, job applicants, visitors and suppliers):	
Contracts with suppliers who are data processors, such as payroll and IT providers:	
Record of data breaches (check the outcomes were handled well):	
Consent forms, where needed (consent is only needed when no other lawful basis applies):	
Data protection impact assessments, where needed (high risk processing, for example new CCTV or biometrics):	
Retention schedule:	
Data protection policy (this policy):	
Data breach procedure (Appendix 1):	
Record of any 'legitimate interests' assessments (not needed for recognised legitimate interests):	
Record of consent:	
ICT and internet acceptable use policy for staff and pupils (our Online Safety and Acceptable Use Policy):	
Record of subject access requests received and completed (check the outcomes were handled well):	

Record of what personal data has been destroyed:	
Information asset register of all the data the school holds:	
Asset register of school IT hardware, including office equipment and mobile devices:	
DATA PROCESSING - evidence of steps taken, future actions, and RAG rating	
We have an appointed DPO:	
We have a data protection lead who helps oversee compliance and is a point of contact for the DPO:	
We have issued privacy notices to everyone whose data we process (if we use an AI tool to process identifiable personal information, the notices must say so):	
We have issued consent forms when we rely on consent as a lawful basis:	
Our DPO reports to the Board at least annually, and whenever there is a data breach or important development:	
We have assessed the risk from our processing to decide the right level of security (the premises and computer systems, the number of staff and their access to data, and data held by processors):	
We have processes for people to make a subject access request, use their other rights, and make complaints about how we use their data (from 19 June 2026, we must help people to complain):	
We have reviewed our data protection policy and procedures for the changes made by the Data (Use and Access) Act 2025:	
All staff understand not to use personal data in generative AI tools unless strictly necessary and approved:	
RECORDS MANAGEMENT - evidence of steps taken, future actions, and RAG rating	

An annual check of the personal data we hold has been done (paper records, databases, online systems, videos and photos):	
Relevant staff have been trained in secure and timely disposal of records:	
An annual audit of the retention schedule has been done, and it matches any changes in law:	
Records have been disposed of in line with the retention schedule:	
Records have been disposed of securely:	
Records have been checked to make sure we are not keeping unnecessary data:	
Personal data kept for analysis has been anonymised where possible:	
SECURITY OF PHYSICAL DOCUMENTS - spot check, with evidence, future actions and RAG rating	
Copies are put away when no one is in the room (clear desk):	
Copies are kept in locked cupboards or cabinets, with the keys in a secure place:	
We keep a record of what copies of personal data have been taken off site:	
Access to copies is limited by role (for example, finance staff do not need safeguarding information):	
All adults on site wear ID, and visitors are signed in and out:	
Office doors are locked when not in use:	
Windows are locked when rooms are not in use:	
Displays only show the essential information about pupils (consider names and photos):	
Displays with sensitive data, such as medical information, are kept away from public areas and covered or removed when used by outside groups:	

Screens cannot be seen through windows:	
SECURITY OF ELECTRONIC DOCUMENTS - spot check, with evidence, future actions and RAG rating	
Computers are locked when not in use, with an automatic lock after 15 to 30 minutes:	
Access to documents on the school system is limited by role (ask IT to show who has access to what):	
Computers are password protected:	
Particularly sensitive documents are password protected:	
USB ports are locked down, with remote access used instead:	
Hard drives, USB drives and laptops are encrypted:	
Email addresses are double checked when sharing data, with autocomplete turned off:	
Emails containing particularly sensitive data are encrypted:	
Emails are checked before attachments or links are opened, to avoid viruses and phishing:	
Emails with personal data are not sent to staff or governors' personal email addresses:	
Printers and copiers are password protected:	
WORKING REMOTELY AND ON VISITS - evidence, future actions and RAG rating	
Physical copies are kept in a secure case or area, and are never left on transport:	
Personal data is not saved on personal devices, but viewed through a remote access system:	
Devices used for remote access are password protected and locked when not in use:	
TRAINING - evidence, future actions and RAG rating	

We have someone responsible for data protection training for staff, governors and volunteers:	
We deliver training each year, or more often if gaps appear, including new risks such as AI:	
We follow up on training to check understanding, for example with a short test:	
Staff and governors have read our data protection policies, and new starters read them:	
Staff and governors know what a data breach is and how to report one:	
Staff and governors can recognise a subject access request and know what to do:	
Staff and governors know what to do if they want to share personal data outside the school, including outside the UK:	
Staff and governors know how to use personal data safely away from the school site:	
OVERALL RESULT	
Summary of the main actions agreed, who is responsible and by when:	
Name and role of the person completing the audit, and the date:	